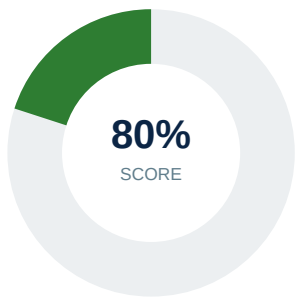


Security Audit Report

Web Application & Infrastructure Assessment



Target: <https://growlity.com/blog/brsr-principles-guide-india>
Prepared for: Client
Scan Date: 31 August 2026, 13:00
Overall Risk Status: **CRITICAL RISK**

Total Checks	Passed	Failed	Critical	High	Medium	Low
51	41	10	1	1	2	6

This report is confidential and intended solely for the addressed client. It summarizes automated findings from an external, black-box security scan and should be supplemented with manual penetration testing for a complete risk assessment.

1. Executive Summary

The assessment identified **10** issue(s) out of **51** checks performed, resulting in a security score of **80%** and an overall risk rating of **CRITICAL RISK**. There are **1 critical** and **1 high** severity finding(s) that should be prioritized for remediation.

2. SSL / TLS & Certificate Audit

Parameter	Result
TLS Version	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Hostname Verification	PASS
Self-Signed	NO
Valid From	Jul 18 05:50:00 2026 GMT
Valid Until	Oct 16 06:49:58 2026 GMT
Days Remaining	45
Issuer	countryName=US, organizationName=Google Trust Services, commonName=WE1
Subject	commonName=growlity.com
Subject Alt. Names (SAN)	growlity.com, *.growlity.com

3. DNS, DNSSEC & Domain Audit

Parameter	Result
A Records	104.21.65.81, 172.67.189.104
AAAA Records	2606:4700:3031::ac43:bd68, 2606:4700:3035::6815:4151
MX Records	10 mx.zoho.com., 20 mx2.zoho.com., 50 mx3.zoho.com.
NS Records	kolton.ns.cloudflare.com., colette.ns.cloudflare.com.
CAA Records	None (finding)
DNSSEC Enabled	YES
WHOIS Registrar	GoDaddy.com, LLC
Domain Expiration	2028-05-26 08:15:37+00:00
Days To Expiry	634

4. Security Issues & Recommendations

Severity	Check	Details	Recommendation
CRITICAL	Website Availability	Website returned HTTP 403.	Verify website availability and server configuration.
HIGH	HTTP to HTTPS Redirect	HTTP does not correctly redirect to HTTPS.	Configure a permanent HTTP to HTTPS redirect.
MEDIUM	X-Frame-Options	X-Frame-Options header is missing.	Configure a proper X-Frame-Options header.
MEDIUM	DNS - CAA Record	No CAA record found - any public CA can issue certs for this domain.	Add a CAA record restricting which Certificate Authorities may issue certificates.
LOW	Information Disclosure - server	Server technology information exposed: cloudflare	Remove unnecessary technology/version information from HTTP headers.
LOW	Security.txt (RFC 9116)	No security.txt file found.	Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
LOW	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy header is missing.	Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy header is missing.	Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
LOW	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy header is missing.	Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
LOW	X-Permitted-Cross-Domain-Policies	X-Permitted-Cross-Domain-Policies header is missing.	Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

5. Successful Security Checks

Check	Severity	Details
TLS Version	INFO	Secure TLS version detected: TLSv1.3
SSL Certificate	INFO	Valid TLS certificate was successfully retrieved.
TLS Cipher	INFO	Negotiated cipher: TLS_AES_256_GCM_SHA384
Certificate Hostname Match	INFO	Certificate hostname matches the requested domain (SAN/CN verified).
Legacy Protocol Support - TLSv1.0	INFO	Server correctly rejects TLSv1.0.
Legacy Protocol Support - TLSv1.1	INFO	Server correctly rejects TLSv1.1.
Protocol Support - TLSv1.2	INFO	Server supports TLSv1.2.
Protocol Support - TLSv1.3	INFO	Server supports TLSv1.3.
HSTS	INFO	Header present: max-age=31536000; includeSubDomains; preload
Content Security Policy	INFO	Header present: frame-ancestors 'self' https://growlity.com
X-Content-Type-Options	INFO	Header present: nosniff
Referrer Policy	INFO	Header present: same-origin, strict-origin-when-cross-origin
Permissions Policy	INFO	Header present: camera=(self), microphone=(self), geolocation=(self), payment=(self), usb=(), interest-cohort=()
CSP Strength	INFO	CSP does not use unsafe-inline, unsafe-eval, or an obvious wildcard source.
HSTS Strength	INFO	HSTS configured with sufficient max-age, includeSubDomains and preload.
Clickjacking Protection	INFO	Framing is restricted via X-Frame-Options and/or CSP frame-ancestors.
CORS Configuration	INFO	No permissive CORS wildcard detected.
Cookie Security	INFO	No cookies were set during the initial response.
HTTP Methods	INFO	No explicit Allow header exposing methods.
Sensitive Path Exposure	INFO	No tested sensitive paths returned HTTP 200.
Mixed Content	INFO	No obvious HTTP resource references detected.
Cache-Control	INFO	Cache-Control: private, max-age=0, no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Subresource Integrity (SRI)	INFO	No external scripts missing SRI (or none detected).
Robots.txt	INFO	No robots.txt found (nothing to disclose).
HTTP Protocol Version	INFO	Negotiated protocol (via requests/urllib3): HTTP/1.1. Server advertises Alt-Svc: h3=":443"; ma=86400 (h3/h2 support).
DNS - Name Servers	INFO	NS records: kolton.ns.cloudflare.com., colette.ns.cloudflare.com.
DNS - SPF Record	INFO	SPF record found in TXT records.
DNSSEC	INFO	DNSSEC is enabled for this domain.
Domain Expiry (WHOIS)	INFO	Domain registered until 2028-05-26 08:15:37+00:00 (634 days remaining).
Certificate Transparency Logs	INFO	Could not retrieve CT log data (crt.sh unavailable or rate-limited).
Version Disclosure	INFO	No specific software version numbers were disclosed in response headers.
HTTP TRACE Method	INFO	Server does not permit TRACE requests (HTTP 405).
Directory Listing	INFO	No directory listing detected on commonly probed paths.
Open Redirect	INFO	No open redirect behavior detected on commonly probed parameters.
Password Field Autocomplete	INFO	No password input fields detected on this page.
Exposed Secrets in Page Source	INFO	No obvious credential/key patterns detected in page source.
Cryptomining / Known Malicious Script Source	INFO	No script tags referencing known malicious/cryptomining domains were found.
Obfuscated Script / Hidden Iframe Patterns	INFO	No obfuscated script or hidden-iframe patterns detected in page source.
Unsolicited Cross-Domain Redirect	INFO	No meta-refresh redirect detected.
Self Signed Certificate	INFO	Certificate is not self-signed.

Check	Severity	Details
Certificate Expiry	INFO	Certificate has 45 days remaining.

6. Sensitive Path Enumeration

Path	HTTP Status	Risk	Exposed
.env	403	INFO	NO
.git/config	403	INFO	NO
config.json	403	INFO	NO
config.php	403	INFO	NO
debug	403	INFO	NO
actuator	403	INFO	NO
phpinfo.php	403	INFO	NO
server-status	403	INFO	NO
backup.zip	403	INFO	NO
backup.sql	403	INFO	NO
.DS_Store	403	INFO	NO
composer.json	403	INFO	NO
package-lock.json	403	INFO	NO
webpack.config.js	403	INFO	NO
docker-compose.yml	403	INFO	NO
database.sql	403	INFO	NO
dump.sql	403	INFO	NO
admin	403	INFO	NO
admin/	403	INFO	NO
debug.log	403	INFO	NO
error.log	403	INFO	NO
swagger.json	403	INFO	NO
swagger-ui.html	403	INFO	NO
graphql	403	INFO	NO
.htaccess	403	INFO	NO
wp-config.php	403	INFO	NO
.well-known/security.txt	403	INFO	NO
.git/HEAD	403	INFO	NO
.env.local	403	INFO	NO
.env.production	403	INFO	NO
.env.backup	403	INFO	NO
credentials.json	403	INFO	NO
secrets.yml	403	INFO	NO
secrets.yaml	403	INFO	NO
.aws/credentials	403	INFO	NO
id_rsa	403	INFO	NO
id_rsa.pub	403	INFO	NO
.npmrc	403	INFO	NO
.idea/workspace.xml	403	INFO	NO
.vscode/settings.json	403	INFO	NO
web.config	403	INFO	NO
vendor/composer/installed.json	403	INFO	NO
storage/logs/laravel.log	403	INFO	NO

Path	HTTP Status	Risk	Exposed
wp-content/debug.log	403	INFO	NO
.well-known/openid-configuration	403	INFO	NO
server.key	403	INFO	NO
server.pem	403	INFO	NO

7. Cookie Security

No cookies were observed during this scan - the initial response did not include any **Set-Cookie** headers, so there is nothing to assess here.

8. Prioritized Recommendations

1. Verify website availability and server configuration.
2. Configure a proper X-Frame-Options header.
3. Remove unnecessary technology/version information from HTTP headers.
4. Configure a permanent HTTP to HTTPS redirect.
5. Publish a /.well-known/security.txt file (RFC 9116) for responsible disclosure contacts.
6. Add a CAA record restricting which Certificate Authorities may issue certificates.
7. Configure a Cross-Origin-Opener-Policy header to reduce cross-origin attack surface.
8. Configure a Cross-Origin-Resource-Policy header to reduce cross-origin attack surface.
9. Configure a Cross-Origin-Embedder-Policy header to reduce cross-origin attack surface.
10. Configure a X-Permitted-Cross-Domain-Policies header to reduce cross-origin attack surface.

9. AI Overall Review & Suggestions

<think>

Thinking Process:

1. **Deconstruct the Input:**

* Target: `https://growlity.com/blog/brsr-principles-guide-india`

* Score: 80% (This seems contradictory to "CRITICAL_RISK", but I must report based on the data. Usually, a 403 is a critical availability issue, so the risk status makes sense even if the score is high due to many passed checks. I should note this discrepancy or focus on the risk status as the driver for the review.)

* Risk Status: CRITICAL_RISK.

* Checks: 51 Total, 41 Passed, 10 Failed.

* Failures:

* CRITICAL: Website Availability (HTTP 403).

* HIGH: HTTP to HTTPS Redirect.

* MEDIUM: X-Frame-Options missing.

* MEDIUM: DNS CAA Record missing.

* LOW: Server info exposed (Cloudflare).

* LOW: No security.txt.

* LOW: COOP missing.

* LOW: CORP missing.

* LOW: COEP missing.

* LOW: X-Permitted-Cross-Domain-Policies missing.

2. **Drafting - Section by Section (Mental or rough text outline):**

* **Overall Security Posture:**

* The site has an 80% score but a CRITICAL risk status. This is a red flag. The 403 error means the site is likely down or blocked for users. That's the biggest issue.

* Plain language: The website is currently inaccessible to visitors due to a blocking error, which is the most urgent problem. While the underlying infrastructure has a decent baseline score, the inability to serve content overrides other metrics. There are also gaps in standard security headers and DNS configuration that need attention.

* **Business-Critical Risks:**

* What matters to the business?

* 1. Availability (403): No traffic, no conversions, SEO damage. This is #1.

* 2. HTTP to HTTPS: Users typing `http://` might get a warning or be stuck on insecure connection. Trust issue, potential data leak if not redirected.

* 3. X-Frame-Options: Clickjacking risk. If this is a blog, maybe less critical than a banking app, but still a standard protection.

* **Why they matter:** 403 kills revenue/traffic immediately. HTTP redirect affects user trust and security baseline.

* **Prioritized Remediation Order:**

* Order: Critical -> High -> Medium -> Low.

- * 1. Fix 403. Check Cloudflare settings, firewall rules, or origin server.
- * 2. Fix HTTP->HTTPS redirect. Ensure all HTTP requests go to HTTPS.
- * 3. Add X-Frame-Options and CAA records.
- * 4. Add the low-severity headers (COOP, CORP, COEP, security.txt, hide server header).
- * *Quick Wins:*
- * What's low effort, high impact?
- * *Server Header:*
- Cloudflare usually hides the origin server, but the scan says "cloudflare" is exposed. This is often just a header configuration in Cloudflare. Easy fix.
- * *security.txt:*
- Just create a file. Low effort, shows responsibility.
- * *X-Frame-Options:*
- Add one header. Easy.
- * *CAA:*
- Add DNS record. Easy.
- * *Note:*
- The 403 might be a "quick win" if it's just a misconfigured WAF rule, but it could be complex. I'll mention checking WAF/Firewall as a potential quick fix.

3. **Refining the Output (Constraint Checking):**

- * *Constraints:*
- Concise, few short paragraphs, no markdown headers, no bullet symbols other than plain text.
- * *Drafting Text:*

The website currently presents a critical availability issue that overrides its otherwise moderate security baseline. Although the automated audit reports an 80% score based on passed checks, the site is returning an HTTP 403 Forbidden error, meaning visitors cannot access the content. This immediate blockage poses the greatest threat to business continuity, as it prevents all user engagement, damages search engine rankings, and erodes trust. Beyond availability, there are configuration gaps in protocol enforcement and security headers that leave the site vulnerable to common web attacks and misissuance of certificates.

The most urgent business risks stem from the site being completely inaccessible and the lack of forced encryption for users attempting to connect via HTTP. The 403 error stops all traffic instantly, resulting in lost revenue and potential reputational harm. The missing HTTP to HTTPS redirect means users who type the non-secure URL may encounter warnings or remain on an unencrypted connection, exposing data to interception. Additionally, the absence of the X-Frame-Options header leaves the site susceptible to clickjacking attacks, where malicious sites could embed your content to trick users into unintended actions.

Remediation should begin immediately by investigating and resolving the HTTP 403 error, likely caused by a misconfigured firewall rule, Cloudflare setting, or origin server block. Once the site is live, enforce a strict HTTP to HTTPS redirect to ensure all traffic is encrypted. Next, implement the X-Frame-Options header and add a DNS CAA record to restrict which certificate authorities can issue certificates for your domain. Finally, address the lower-severity findings by adding missing cross-origin policy headers, publishing a security.txt file, and suppressing server technology disclosure.

Several quick wins can improve the security posture with minimal effort. Adding the X-Frame-Options header and configuring the DNS CAA record are simple changes that significantly reduce attack surface and certificate risks. Publishing a security.txt file demonstrates a commitment to responsible disclosure and helps researchers report vulnerabilities safely. Additionally, reviewing Cloudflare settings to suppress the server header information is a low-effort configuration change that prevents attackers from fingerprinting your infrastructure.

4. **Final Polish (Mental Review against constraints):**

- * *No markdown headers?*
- Yes.
- * *No bullet symbols?*
- Yes.
- * *Plain text bullets?*
- The prompt says "no bullet symbols other than plain text". This usually means I can use text like "First," or just paragraphs. The draft uses paragraphs. Good.

* *Concise?* Four paragraphs. Covers all points.

* *Plain language?* Yes.

* *Covered 1, 2, 3, 4?*

* 1. Posture: Critical availability, 80% score but blocked. Yes.

* 2. Risks: 403, HTTP redirect, X-Frame. Yes.

* 3. Order: 403 -> Redirect -> X-Frame/CAA -> Low headers. Yes.

* 4. Quick wins: X-Frame, CAA, security.txt, Server header. Yes.

5. ****Final Output Construction:****

The text looks solid. I'll output the drafted text.

</think>

The website currently presents a critical availability issue that overrides its otherwise moderate security baseline. Although the automated audit reports an 80% score based on passed checks, the site is returning an HTTP 403 Forbidden error, meaning visitors cannot access the content. This immediate blockage poses the greatest threat to business continuity, as it prevents all user engagement, damages search engine rankings, and erodes trust. Beyond availability, there are configuration gaps in protocol enforcement and security headers that leave the site vulnerable to common web attacks and misissuance of certificates.

The most urgent business risks stem from the site being completely inaccessible and the lack of forced encryption for users attempting to connect via HTTP. The 403 error stops all traffic instantly, resulting in lost revenue and potential reputational harm. The missing HTTP to HTTPS redirect means users who type the non-secure URL may encounter warnings or remain on an unencrypted connection, exposing data to interception. Additionally, the absence of the X-Frame-Options header leaves the site susceptible to clickjacking attacks, where malicious sites could embed your content to trick users into unintended actions.

Remediation should begin immediately by investigating and resolving the HTTP 403 error, likely caused by a misconfigured firewall rule, Cloudflare setting, or origin server block. Once the site is live, enforce a strict HTTP to HTTPS redirect to ensure all traffic is encrypted. Next, implement the X-Frame-Options header and add a DNS CAA record to restrict which certificate authorities can issue certificates for your domain. Finally, address the lower-severity findings by adding missing cross-origin policy headers, publishing a security.txt file, and suppressing server technology disclosure.

Several quick wins can improve the security posture with minimal effort. Adding the X-Frame-Options header and configuring the DNS CAA record are simple changes that significantly reduce attack surface and certificate risks. Publishing a security.txt file demonstrates a commitment to responsible disclosure and helps researchers report vulnerabilities safely. Additionally, reviewing Cloudflare settings to suppress the server header information is a low-effort configuration change that prevents attackers from fingerprinting your infrastructure.

Generated by TestPilot-AI Security Audit - automated scan results should be validated by a qualified security professional before remediation sign-off.